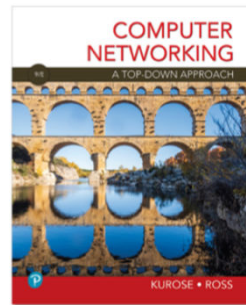


第 8 章 网络安全

中国科学技术大学
自动化系 郑烜
改编自Jim kurose, Keith Ross



Computer Networking: A Top-Down Approach
9th edition
Jim Kurose, Keith Ross
Pearson, 2025

网络安全

本章目标：

- 网络安全原理：
 - 加密，不仅仅用于机密性
 - 认证
 - 报文完整性
- 网络安全实例：
 - 各个层次安全协议的例子
 - 应用层，传输层，网络层和链路层
 - 防火墙和入侵检测系统：IDS

第八章 提纲

- 什么是网络安全？
- 加密原理
- 认证，报文签名，报文完整性，共享密钥协商
- 安全电子邮件
- 使TCP连接安全：TLS
- 网络层安全性：IPSec
- 无线和移动网络的安全
- 实践中的网络安全：防火墙和IDS



什么是网络安全？

机密性：只有发送方和指定的接收方能否理解传输的报文内容

- 发送方加密报文
- 接收方解密报文

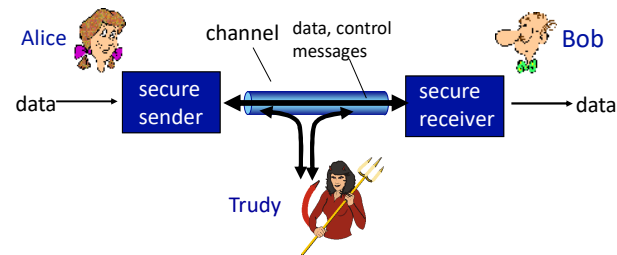
认证：发送方和接收方需要确认对方的身份

报文完整性：发送方、接受方需要确认报文在传输的过程中或者事后没有被改变

访问控制和服务的可用性：服务可以接入以及对用户而言是可用的

朋友和敌人: Alice, Bob, Trudy

- 网络安全世界比较著名的模型
- Bob, Alice (lovers!) 需要安全的通信
- Trudy (intruder) 可以截获, 删除和增加报文



Security: 8- 5

朋友和敌人: Alice, Bob, Trudy

谁有可能是Bob, Alice?

- ... 现实世界中的Bobs和Alices!
- 电子交易中的Web browser/server (e.g., 在线购买)
- 在线银行的client/server
- DNS 服务器
- BGP路由器做路由信息的交换
- 其它例子?

网络中存在这坏蛋!

Q: "bad guy"可以干什么?

A: 很多! (recall section 1.6)

- **窃听**: 截获报文
- **插入**: 主动在连接上插入报文
- **伪装**: 可以在分组的源地址写上伪装的地址
- **劫持**: 将发送方或者接收方踢出, 接管连接
- **拒绝服务**: 阻止服务被其他正常用户使用 (e.g., 通过对资源的过度使用)

第八章 提纲

- 什么是网络安全?
- **加密原理**
- 认证, 报文签名, 报文完整性, 共享密钥协商
- 安全电子邮件
- 使TCP连接安全: TLS
- 网络层安全性: IPSec
- 无线和移动网络的安全
- 实践中的网络安全: 防火墙和IDS



Security: 8- 8

一个更加复杂的加密方法

- n 个替换密码, $M_1, M_2, \dots, M_n$
- 循环模式:
 - e. g., $n=4$: M_1, M_3, M_4, M_3, M_2 ; M_1, M_3, M_4, M_3, M_2 ; ..
- 对于每个明文字符, 采用循环替换模式的下一个
 - dog: d from M_1 , o from M_3 , g from M_4

加密的密钥: n 个替换模式 (字母替换表) 和循环模式

- 密钥不仅仅是: 字母之间的映射模式

Security: 8- 13

对称密钥加密: DES

DES: Data Encryption Standard

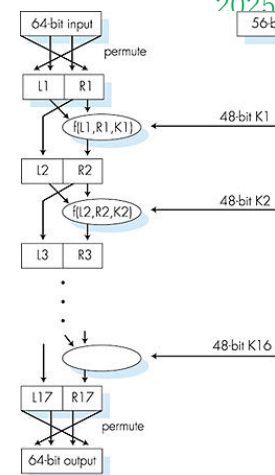
- US 加密标准[NIST 1993]
- 56-bit 对称密钥, 64-bit明文输入
- 块加密、密码块链
- DES有多安全?
 - DES挑战: 56-bit密钥加密的短语 (“Strong cryptography makes the world a safer place”) 采用暴力解密, 不到一天时间
 - 可能有后门?
- 使DES更安全:
 - 使用3个key、3重DES 运算
 - 密文分组串技术

Security: 8- 14

对称密钥加密: DES

DES: Data Encryption Standard

- 初始替换
- 16 轮一样的函数应用, 每一轮使用的不同的 48bit密钥
- 最终替换



Security: 8- 15

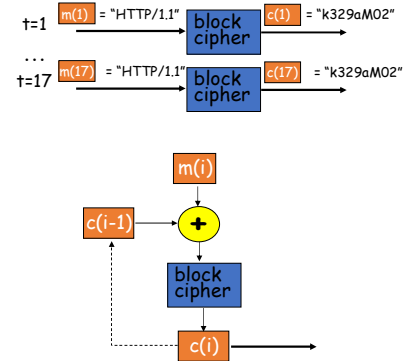
AES: Advanced Encryption Standard

- 新的对称加密NIST标准 (Nov. 2001) 用于替换 DES
- 数据128bit成组加密
- 128, 192, or 256 bit keys
- 暴力法解密如果使用1秒钟破解 DES, 需要花149万亿年
破解AES

Security: 8- 16

密码块链

- **密码块**：如果输入块重复，将会得到相同的密文块
- **密码块链**：第*i*轮输入 $m(i)$ ，与前一轮的密文， $c(i-1)$ 做异或



Security: 8- 17

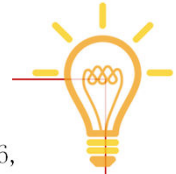
公开密钥密码

对称加密：

- 需要发送方和接收方对共享式对称密钥达成一致
- Q：但是他们如何第一次达成一致（特别是他们永远不可能见面的情况下）？

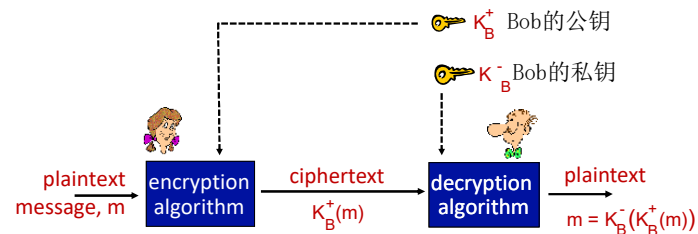
公开密钥加密

- 完全不同的方法 [Diffie-Hellman76, RSA78]
- 发送方和接收方**无需**共享密钥
- 一个实体的**公钥**公之于众
- **私钥**只有接收方自己知道



Security: 8- 18

公开密钥加密



Wow - 公钥密码学彻底改变了2000年（以前只有对称密钥）的密码学！

- 同样的想法几乎同时、且独立地出现在美国 and 英国

Security: 8- 19

公开密钥加密算法

要求：

- ① need $K_B^+(\cdot)$ and $K_B^-(\cdot)$ such that $K_B^-(K_B^+(m)) = m$
- ② 给定公钥 K_B^+ ，导出私钥 K_B^- 计算上不可行

RSA: Rivest, Shamir, Adelson algorithm

Security: 8- 20

预先知识：模运算

- $x \bmod n = x$ 除以 n 得到的余数
- 一些事实：
 - $[(a \bmod n) + (b \bmod n)] \bmod n = (a+b) \bmod n$
 - $[(a \bmod n) - (b \bmod n)] \bmod n = (a-b) \bmod n$
 - $[(a \bmod n) * (b \bmod n)] \bmod n = (a*b) \bmod n$
- 因此
 - $(a \bmod n)^d \bmod n = a^d \bmod n$
- 例子： $x=14, n=10, d=2$:
 - $(x \bmod n)^d \bmod n = (14 \bmod 10)^2 \bmod 10 = 4^2 \bmod 10 = 6$
 - $x^d = 14^2 = 196 \quad x^d \bmod 10 = 6$

Security: 8- 21

RSA：准备

- 报文：就是一个bit模式
 - Bit模式可以唯一的用整数来表示
 - 因此，加密一个报文就等于加密一个整数
- 例子：
- $m = 10010001$ 报文可以唯一的用十进制数145来代替.
 - 为了加密 m ，即加密相应的整数，得到一个新的整数(密文)

Security: 8- 22

RSA：创建公钥/私钥对

1. 选择2个很大的质数 p, q . (例如：每个1024 位)
2. 计算 $n = pq, z = (p-1)(q-1)$
3. 选择一个 e (要求 $e < n$) 和 z 没有一个公共因子，互素 ("relatively prime").
4. 选择 d 使得 $ed-1$ 正好能够被 z 整除.
(也就是: $ed \bmod z = 1$).
5. 公钥 (n, e) . 私钥 (n, d) .

$\underbrace{(n, e)}_{K_B^+}$

$\underbrace{(n, d)}_{K_B^-}$

Security: 8- 23

RSA：加密和解密

0. 给定按照上述算法得到的 (n, e) 和 (n, d)
1. 加密报文 $m (< n)$, 加密算法
 - $c = m^e \bmod n$
2. 对接收到的密文 c 解密，如此计算
 - $m = c^d \bmod n$

magic happens! $m = (\underbrace{m^e \bmod n}_c)^d \bmod n$

Security: 8- 24

RSA例子:

2025中科大高网

Bob 选择 $p=5, q=7$. 因此 $n=35, z=24$.
 $e=5$ (so e, z 互素).
 $d=29$ (so $ed-1$ 能够被 z 整除).

加密 8-bit 报文

encrypt: bit pattern m m^e $c = m^e \bmod n$
 00001100 12 24832 17

decrypt: c c^d $m = c^d \bmod n$
 17 481968572106750915091411825223071697 12

Security: 8- 25

为什么RSA可行? $m = (m^e \bmod n)^d \bmod n$

2025中科大高网

一个有用的数论定理: 如果 p, q 都是素数, $n = pq$, 那么:

$$\begin{aligned}
 x^{y \bmod n} &= x^{y \bmod (p-1)(q-1)} \bmod n \\
 (m^e \bmod n)^d \bmod n &= m^{ed} \bmod n \\
 &= m^{ed \bmod (p-1)(q-1)} \bmod n \\
 &\quad \text{(使用上述定理)} \\
 &= m^1 \bmod n \\
 &\quad \text{(因为我们选择 } ed, \text{ 使得被 } z \text{ 除正好余 } 1) \\
 &= m
 \end{aligned}$$

26

Security: 8- 26

RSA: 另外一个重要的特性

2025中科大高网

下面的特性将在后面非常有用:

$$K_B^-(K_B^+(m)) = m = K_B^+(K_B^-(m))$$

先用公钥, 然后
后用私钥

先用私钥, 然后
后用公钥

结果一致!

Security: 8- 27

为什么 $K_B^-(K_B^+(m)) = m = K_B^+(K_B^-(m))$?

2025中科大高网

直接遵循求模的运算法则:

$$\begin{aligned}
 (m^e \bmod n)^d \bmod n &= m^{ed} \bmod n \\
 &= m^{de} \bmod n \\
 &= (m^d \bmod n)^e \bmod n
 \end{aligned}$$

结论可以用于数字签名

Security: 8- 28

为什么RSA安全?

- 假设知道了Bob的公钥 (n, e) ，求解私钥 d 的难度有多大 (n, d) ?
- 本质上是在不知道2个因子 p 和 q 的情况下，求解 n 的因子
 - 事实是：分解一个大的整数是非常困难的

Security: 8- 29

RSA实践：会话密钥

- RSA中的指数运算计算代价巨大
- DES比RSA快最少100倍
- 采用公开密钥加密体系建立安全连接，之后建立第二个密钥-对称式会话密钥-用于加密数据

会话密钥, K_s

- Bob和Alice使用RSA来交换对称式会话密钥 K_s
- 一旦双方拥有了 K_s ，他们使用对称式密钥进行加密

Security: 8- 30

采用公开密钥加密技术



我们将会看到很多公开密钥加密技术的非加密用法

- 认证
- 数字签名
- 报文完整性
- 对称式密钥的协商

Wireless network security 31

实践中的RSA：会话密钥

- 在RSA中求幂次方的运算代价非常大
- DES（对称加密）最起码比RSA快100倍
- 采用公开密钥加密体系创建一个安全的连接，然后建立第二个对称密钥 K_s ，用于实际加密数据

会话密钥, K_s

- Bob 和 Alice 采用RSA交换对称密钥 K_s
- 一旦拥有了 K_s ，采用对称加密来进行加密和解密

Security: 8- 32

第八章 提纲

- 什么是网络安全?
- 加密原理
- **认证**, 报文签名, 报文完整性, 共享密钥协商
- 安全电子邮件
- 使TCP连接安全: TLS
- 网络层安全性: IPSec
- 无线和移动网络的安全
- 实践中的网络安全: 防火墙和IDS

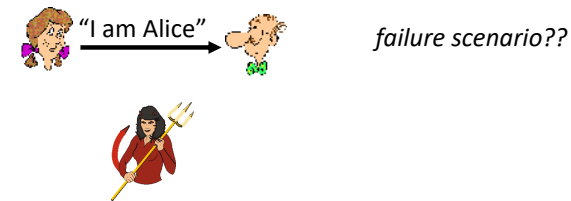


Security: 8- 33

认证

目标: Bob需要Alice “证明” 她的身份

Protocol ap1.0: Alice 说“I am Alice”

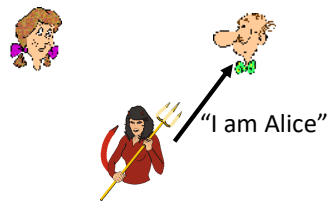


Security: 8- 34

认证

目标: Bob需要Alice “证明” 她的身份

Protocol ap1.0: Alice 说“I am Alice”



在网络中, Bob
看不到Alice,
所以Trudy简单
申明其是Alice

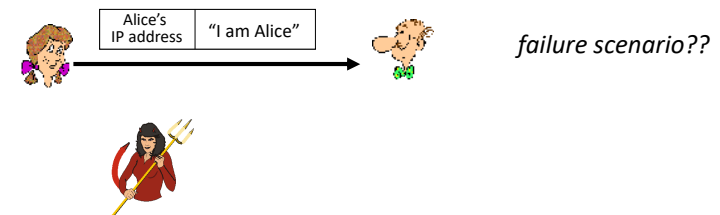


Security: 8- 35

认证: 新的尝试

目标: Bob需要Alice “证明” 她的身份

Protocol ap2.0: Alice 说 “I am Alice”, 具备Alice的IP地址



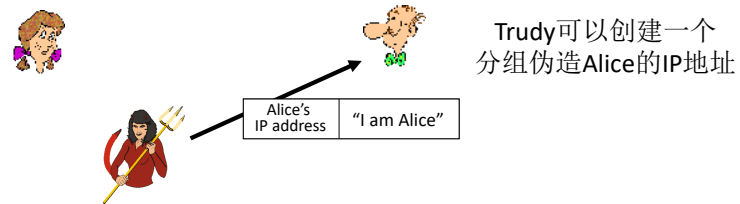
Security: 8- 36

2025中科大高网

认证：新的尝试

目标: Bob需要Alice “证明” 她的身份

Protocol ap2.0: Alice 说 “I am Alice”， 具备Alice的IP地址



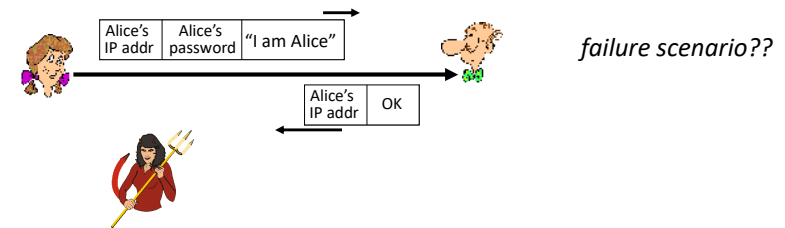
Security: 8- 37

2025中科大高网

认证：第三次尝试

目标: Bob需要Alice “证明” 她的身份

Protocol ap3.0: Alice说 “I am Alice”， 而且传送她的密码来证明其身份



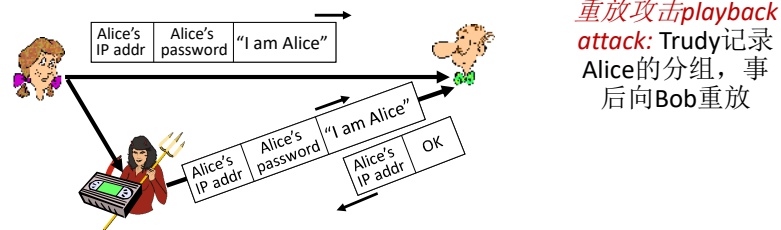
Security: 8- 38

2025中科大高网

认证：第三次尝试

目标: Bob需要Alice “证明” 她的身份

Protocol ap3.0: Alice说 “I am Alice”， 且传送她的密码来证明



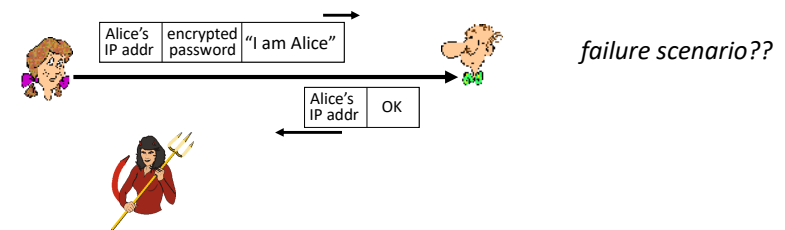
Security: 8- 39

2025中科大高网

认证：升级的第三次尝试

目标: Bob需要Alice “证明” 她的身份

Protocol ap3.0: Alice 说 “I am Alice”， 而且传送她的加密之后的密码来证明



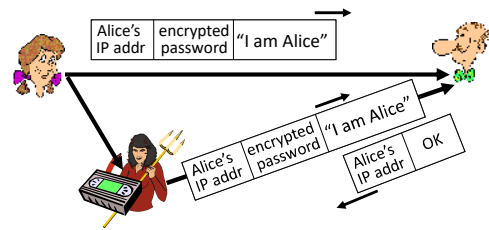
Security: 8- 40

认证: 升级的第三次尝试

2025中科大高网

目标: Bob需要Alice “证明” 她的身份

Protocol ap3.0: Alice 说 “I am Alice”, 而且传送她的加密之后的密码来证明



重放攻击仍然有效:
Trudy 记录records
Alice的分组, 然后
过后重放给Bob

Security: 8- 41

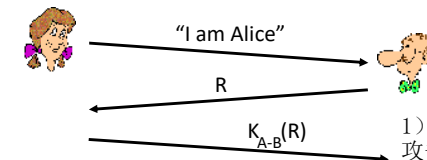
认证: 第四次尝试 (利用对称加密方法)

2025中科大高网

目标: 避免重放攻击

Nonce: 一个协议生存期只用一次的整数 (R)

protocol ap4.0: 为了证明Alice的活跃性, Bob发送给Alice一个nonce R. Alice返回加密之后的R, 使用双方约定好的key



Failures, drawbacks?

- 1) nonce从来没用过, 重放攻击不起作用;
- 2) 对方知道和Bob共享的密钥 K_{A-B} 只有 Alice知道; Bob的对方一定是Alice!

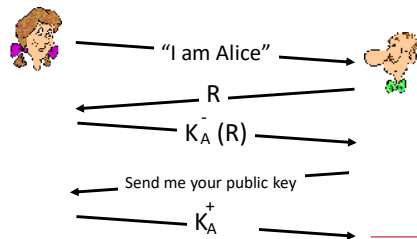
Security: 8- 42

认证: ap5.0 (利用非对称加密)

2025中科大高网

ap4.0 需要双方共享一个对称式的密钥-是否可以通过公开密钥技术进行认证呢?

ap5.0: 使用nonce R, 公开密钥加密技术



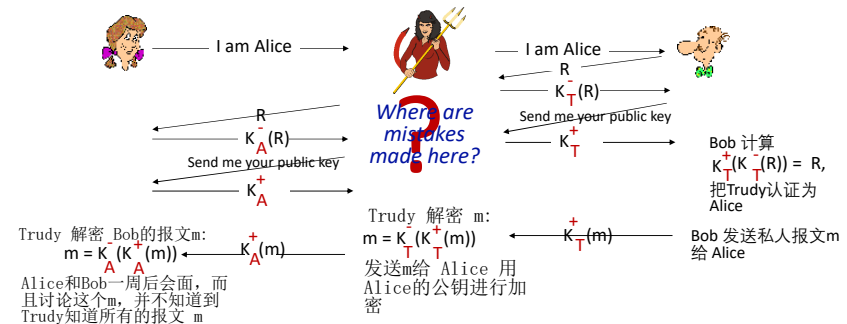
Bob 计算
 $K_A^+ (K_A^- (R)) = R$
 只有 Alice 拥有该私钥,
 才能得到 $K_A^- (R)$
 $K_A^+ (K_A^- (R)) = R$

Security: 8- 43

认证: ap5.0 – 安全漏洞!

2025中科大高网

中间攻击: Trudy 在 Alice (to Bob)和 Bob之间 (to Alice)



Security: 8- 44

认证: ap5.0 – 安全漏洞!

中间攻击: Trudy 在 Alice (假装成 Bob)和 Bob之间 (假装成Alice)



难以检测:

- Bob收到了Alice发送的所有报文, 反之亦然. (e.g., so Bob, Alice一个星期以后相见, 回忆起以前的会话)
- 问题是Trudy也接收到了所有的报文!

- **本质:** Bob没有拿到真正Alice的公钥
- 如果能够可靠地拿到Alice的公钥, 那么采用公开密钥体系就行认证也是可行的

Security: 8- 45

第八章 提纲

- 什么是网络安全?
- 加密原理
- 认证, **报文签名**, **报文完整性**, 共享密钥协商
- 安全电子邮件
- 使TCP连接安全: TLS
- 网络层安全性: IPSec
- 无线和移动网络的安全
- 实践中的网络安全: 防火墙和IDS

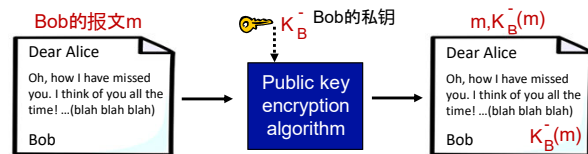


Security: 8- 46

数字签名

数字签名类似于手写签名:

- 发送方 (Bob) 数字签署了文件, 前提是他(她)是文件的拥有者/创建者.
- **可验证性, 不可伪造性:** 接收方 (Alice)可以向其他人证明是一定Bob而不是其他人 (包括Alice自己) 伪造地签署了该报文
- **报文m的简单数字签名:**
 - Bob使用其私钥对m进行了签署, 创建数字签名的 $K_B^-(m)$



Security: 8- 47

数字签名

- 假设Alice收到报文m, 以及数字签名 $K_B^-(m)$
Alice 使用Bob的公钥 K_B^+ 对 $K_B^-(m)$ 进行验证, 判断 $K_B^+(K_B^-(m)) = m$ 是否成立?
- 如 $K_B^+(K_B^-(m)) = m$ 成立, 那么签署这个文件的人一定拥有Bob的私钥.

Alice 可以验证:

- ✓ Bob 签署了m, 不是其他人签署了m.
- ✓ Bob签署了m 而不是m'.

不可抵赖性:

- ✓ Alice 可以拿着m, 以及数字签名 $K_B^-(m)$ 到法庭上, 来证明是Bob签署了这个文件 m.

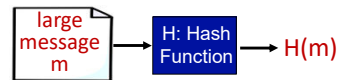
Security: 8- 48

报文摘要

2025中科大高网

对长报文进行公开密钥加密算法的运行需要耗费大量的时间

Goal: 固定长度, 容易计算的**指纹 (fingerprint)** 对 m 使用散列函数 H , 获得固定长度的报文摘要 $H(m)$



散列函数的特性:

- 多对1
- 结果固定长度
- 给定一个报文摘要 x , 反向计算出原报文在计算上是不可行的 $x = H(m)$

Security: 8- 49

Internet校验和: 弱的散列函数

2025中科大高网

Internet 校验和拥有一些散列函数的特性:

- 产生报文 m 的固定长度摘要 (16-bit sum)
- ✓ 多对1的

但给定一个散列值, 很容易计算出另外一个报文具有同样散列值:

message	ASCII format	message	ASCII format
I O U 1	49 4F 55 31	I O U 9	49 4F 55 39
0 0 . 9	30 30 2E 39	0 0 . 1	30 30 2E 31
9 B O B	39 42 D2 42	9 B O B	39 42 D2 42
B2 C1 D2 AC		B2 C1 D2 AC	

不同的报文 但是相同的校验和!

Security: 8- 50

散列函数算法

2025中科大高网

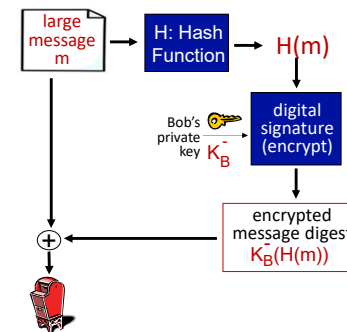
- **MD5散列函数 (RFC 1321) 被广泛地应用**
 - 4个步骤计算出128-bit的报文摘要
 - 给定一个任意的128-bit串 x , 很难构造出一个报文 m 具有相同的MD5摘要
- **SHA-1也被使用**
 - US标准 [NIST, FIPS PUB 180-1]
 - 160-bit报文摘要

Security: 8- 51

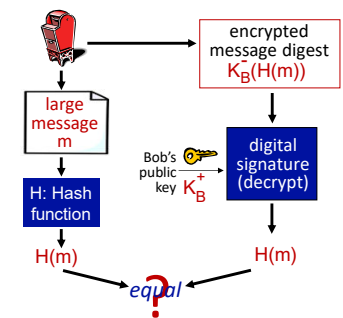
数字签名 = 对报文摘要进行数字签署

2025中科大高网

Bob 发送数字签名的报文:



Alice 校验签名和报文完整性:

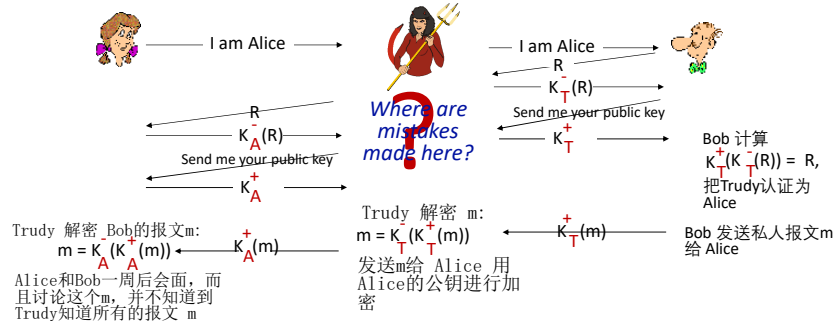


Security: 8- 52

修复ap5.0的安全漏洞

2025中科大高网

回顾中间攻击的问题: Trudy 站在Alice (假扮Bob)和 Bob (假扮Alice)之间



Security: 8-53

需要认证的公钥

2025中科大高网

动机: Trudy对Bob做一个披萨恶作剧

- Trudy 创建一个 e-mail 订单: 亲爱的披萨店, 请送4个辣味意大利香肠披萨给我, 谢谢, Bob
- Trudy 采用自己的私钥签署了这个订单
- Trudy 发送这个订单给披萨店
- Trudy 将自己的公钥发给披萨店, 说这是 Bob 的公钥
- Pizza 店验证该签名; 然后发了4个辣味意大利香肠披萨给 Bob
- Bob 甚至不喜欢辣味意大利香肠披萨

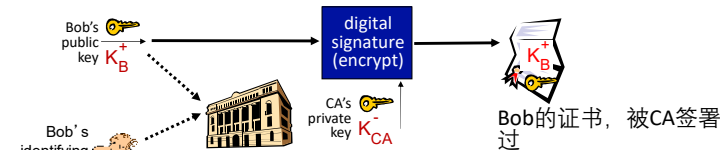


Security: 8-54

公钥认证中心 (CA)

2025中科大高网

- certification authority (CA):** 将一个公钥和拥有它的实体 E 做个捆绑
- E (person, router) 到 CA 那里注册他的公钥 (带外的), E 提供给 CA, 自己身份的据 “proof of identity”
 - CA 创建一个证书, 捆绑了 E 实体信息和他的公钥;
 - Certificate 包括了 E 的公钥, 而且是被 CA 签署的 (被 CA 用自己的私钥加密的) – CA 说 “this is E's public key”



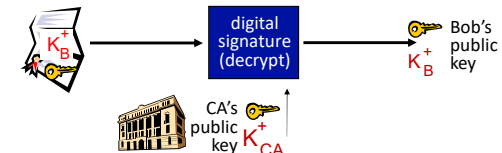
Security: 8-55

公钥认证中心 (CA)

2025中科大高网

当 Alice 需要拿到 Bob 公钥:

- 获得 Bob 的证书 certificate (从 Bob 或者其他地方)
- 使用 CA 的公钥来验证 Bob 的证书
 - 前提是之前需要可靠地获得 CA 的公钥, CA 的证书
 - CA 证书获得带外方式: 安装系统带的, 或者直接信赖的这个公钥
 - CA 证书一般是自己用自己的私钥签署自己的公钥



Security: 8-56

互联网的信任树

- **根证书**：根证书是未被签名的公钥证书或自签名的证书
 - “带外”式地拿到一些CA的公钥
 - 渠道：安装OS自带的数字证书；从网上下载你认为可以信任的数字证书
- **信任树**：
 - 信任根证书CA颁发的证书，拿到了根CA的公钥
 - 信任了根
 - 由根CA签署了，这些机构的数字证书（包含了该机构的公钥）
 - 由于你信任了根，从而能够“可靠地”拿到根CA签发的证书，“可靠地”拿到这些机构的公钥

Security: 8- 57

第八章 提纲

- 什么是网络安全？
- 加密原理
- 认证，报文签名，报文完整性，**共享密钥协商**
- 安全电子邮件
- 使TCP连接安全：TLS
- 网络层安全性：IPSec
- 无线和移动网络的安全
- 实践中的网络安全：防火墙和IDS



Security: 8- 58

采用公开密钥加密体系进行共享密钥的协商

问题：对于Bob和Alice来说，他们要使用对称式加密技术，首先需要就共享式密钥达成一致

- 如果他们从来没见过面，如何进行？
- **使用公开密钥加密体系可以解决这个问题！**

Diffie-Hellman (DH) 公钥/私钥：与RAS不同的算法！



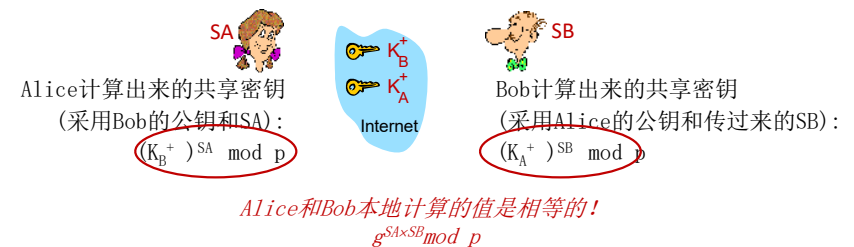
- Bob 选择**公开值**：大素数 p ，另外一个大整数 g ($< p$, p 的元根)， p , g 传给Alice
- Alice和Bob独立选择**私有值**： SA , SB
- Alice的**公钥**： $K_A^+ = g^{SA} \bmod p$ (第二个报文传给Bob)
- Bob的**公钥**： $K_B^+ = g^{SB} \bmod p$ (第一个报文传给Alice)

Wireless network security 59

采用公开密钥加密体系进行共享密钥的协商

Diffie-Hellman (DH) 公钥密钥的导出：

- Alice, Bob在无需显式交换共享会话密钥的情况下，计算公共的共享密钥！
- Alice, Bob拥有了DH公钥： K_A^+ , K_B^+ ，密钥 SA , SB



Wireless network security 60

第八章 提纲

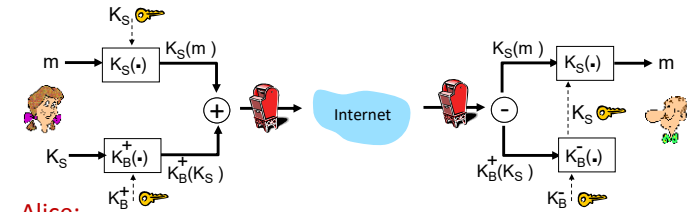
- 什么是网络安全?
- 加密原理
- 认证, 报文签名, 报文完整性, 共享密钥协商
- **安全电子邮件**
- 使TCP连接安全: TLS
- 网络层安全性: IPSec
- 无线和移动网络的安全
- 实践中的网络安全: 防火墙和IDS



Security: 8- 61

安全电子邮件：机密性

Alice需要发送机密的报文 m 给Bob.



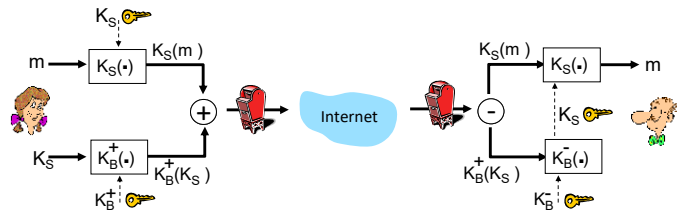
Alice:

- 产生随机的对称密钥, K_S
- 使用 K_S 对报文加密(为了效率)
- 对 K_S 使用 Bob的公钥进行加密.
- 发送 $K_S(m)$ 和 $K_B(K_S)$ 给 Bob.

Security: 8- 62

安全电子邮件：机密性（续）

Alice需要发送机密的报文 m 给Bob.



Bob:

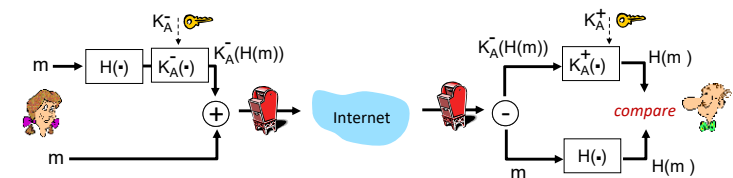
- 使用自己的私钥解密 K_S
- 使用 K_S 解密 $K_S(m)$ 得到报文

- 利用对称加密无需共享密钥
- 也具备对称加密的高效

Security: 8- 63

安全电子邮件：完整性和可认证性

• Alice 需要提供源端的报文完整性和可认证性

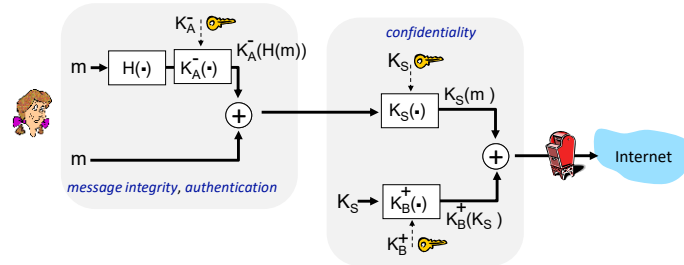


- Alice 数字签署文件(采用自己的私钥签署报文的散列)
- 发送报文（明文）和 数字签名

Security: 8- 64

安全电子邮件：私密性、完整性和可认证性

Alice 需要提供机密性，源端可认证性和报文的完整性



Alice用了3个keys: 自己的私钥, Bob的公钥, 新产生的对称式密钥
Bob端的对应动作是?

Security: 8- 65

第八章 提纲

- 什么是网络安全?
- 加密原理
- 认证, 报文签名, 报文完整性, 共享密钥协商
- 安全电子邮件
- 使TCP连接安全: TLS**
- 网络层安全性: IPSec
- 无线和移动网络的安全
- 实践中的网络安全: 防火墙和IDS



Security: 8- 66

Transport-layer security (TLS)

- 广泛部署的安全协议
 - 被几乎所有浏览器和Web服务器采用, 如: https
 - 被QUIC采用 (协作): 握手时的认证和秘钥集协商, 之后的加密数据传输
 - https (Port 443)
- 能够提供
 - 机密性**: 采用对称加密
 - 完整性**: 通过加密的散列值 (对称加密, nonce参与, hash)
 - 认证**: 通过公开秘钥加密体系

所有的技术我们都学过!
- 历史
 - 早期的研究和实现: 安全网络编程, 安全套接字接口
 - SSL3.0 RFC7568 (1996) $\rightarrow$ TLS 1.0 (1999)
 - TLS1.2 RFC 5246 (2008)
 - TLS1.3 RFC 8846 (2018)

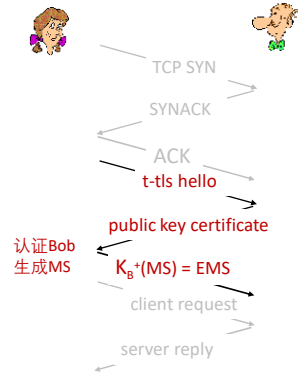
Security: 8- 67

Transport-layer security: 需求是什么?

- 渐进式地构建起一个玩具版的TLS协议: $t-tls$
- 安全通信的4个步骤:
 - 握手**: Alice和Bob使用各自证书, 私钥来认证对方, 交换或者创建共享密钥 (对称密钥)
 - 秘钥导出**: Alice和Bob采用共享秘钥来生成一个密钥集
 - 数据传输**: 要传输的数据被分成若干记录的序列 (数据块)
 - 不仅仅是一次性的事务性交互
 - 连接关闭**: 采用特殊的报文安全关闭连接

Security: 8- 68

t-tls:初始化握手



t-tls 握手阶段:

- Alice建立和Bob的TCP连接
- Alice验证的Bob的身份
 - 用CA的公钥
 - 验证Bob的证书
- Alice生成会话所使用的主密钥MS
 - 用Bob的公钥 key_B^+ 加密主密钥
 - 将 $key_B^+(MS)$ 传给Bob
- 可能存在的问题:
 - 在通信之前需要花费3 RTT (包括TCP连接建立)

Security: 8- 69

t-tls:密钥生成

- 如在多个加密操作中采用同一个密钥: **不安全**
 - 采用不同的密钥用于: **报文认证 (MAC)** 和 **加密**
- 4个key:
 - K_c = C到S的加密密钥
 - M_c = C到S的MAC密钥
 - K_s = S到C的加密密钥
 - M_s = S到C的MAC密钥
- 密钥由密钥key derivation function (KDF) 导出函数导出
 - KDF的输入: 主密钥MS + (可能的) 一些附加随机数据 (IV)
 - IV的加入破除了主密钥MS 和 4个Key的固定对应关系

Security: 8- 70

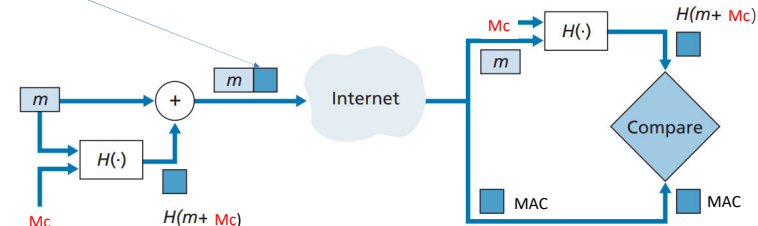
t-tls:加密数据

- 回顾: TCP提供数据字节流传输的服务
- Q: t-tls可以对数据进行**流式加密**吗? 就像TCP Socket
 - 4: 如是流式加密, **完整性校验的MAC**只能在最后, 那么只有所有数据都被传输完毕才能够进行**完整性校验**!
 - 如: 对于即时通信 (持续时间很长), 在终端显示这些字符之前, 如何对 **所有字节** 进行完整性校验?
 - 方案: 将字节流分割成一个个的**记录**
 - 每个记录C-S携带该记录的MAC=hash (采用 M_c)
 - 接收端可以对每个到达的记录进行完整性校验 (用了 M_c 也有源端认证的含义)
- t-tls记录采用对称密钥 K_c 加密, 交付给TCP传输: **MAC=HASH(data+ M_c)**



Security: 8- 71

MAC: 报文认证码



Key:

m = Message

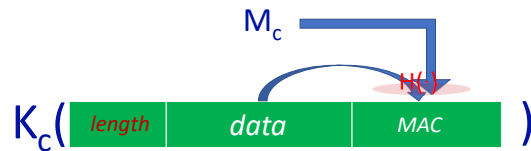
Mc = Shared secret

- 如果简单采用Hash作为MAC, 问题是: 攻击方可将报文 m 替换成: m' , $H(m)$ 替换成 $H(m')$
- 方法: 将Secret= Mc , 加入到hash的运算, $H(m+Mc)$
- 不需要加密, 更不用采用代价高的私钥加密签署
 - m 和 $H(m+s)$ 反正要加密, 即 m 和MAC的外面用 K_c 加密

Security: 8- 72

t-tls:加密数据

- Q: 在记录中, 接收端要区分data与MAC
 - 采用可变长记录, 用length指示数据长度
 - $MAC = MAC(data, M_c)$: MAC依赖于data和 M_c , 更安全
 - Data和MAC加密传输, 用 K_c
- t-tls记录采用对称密钥加密, 密钥为 K_c , 交付给TCP传输:



Security: 8-73

t-tls:加密数据 (续1)

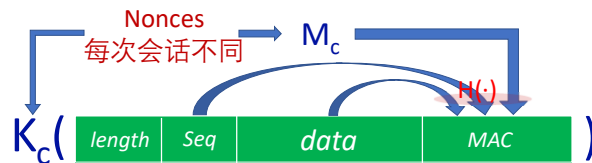
- 针对数据流的可能攻击?
 - **重排攻击**: 中间攻击者可以捕获、重新排序攻击
 - Client→Server 2个TCP段
 - 中间人Trudy颠倒2个TCP段的序号 (TCP段没有加密, 可以修改TCP头部序号)
 - Server TCP收到, 交TLS, 上交应用
 - 那么应用将无法检查出颠倒的问题
- 方案: 将记录的序号放到MAC中, $MAC = MAC(M_c, \text{sequence} || data)$
 - 发送者TLS使用记录序号0, 1, 2... (每发送一个, 序号加1)
 - 记录的序号加入到MAC的运算



Security: 8-74

t-tls:加密数据 (续2)

- 针对数据流的可能攻击?
 - **重放攻击**: 攻击者重放所有的记录
- 方案: 采用不重数nonce
 - 每次TLS握手, 采用不同的nonce
 - 密钥4keys依赖于不重数nonce, 每次连接密钥 K_c , M_c , K_s , M_s 都不同
 - 重放攻击不起作用



Security: 8-75

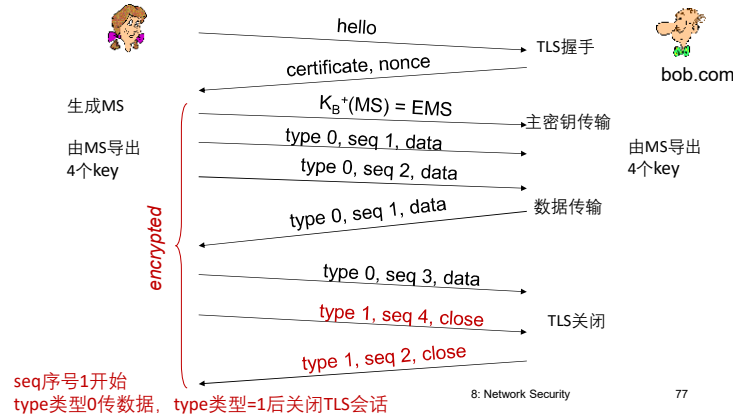
t-tls: 连接关闭

- 截断攻击:
 - 攻击者伪造TCP连接关闭的报文段: 伪造TCP连接关闭
 - 连接过早地被关闭, 一方或者双方只接收到了比实际少的数据
- 方案: TLS记录类型, 一个类型用于关闭
 - 类型0用于数据; 类型1用于关闭 (最后一个数据段)
 - TLS会话记录type=1传输之后, 才是TCP连接关闭
 - 本质上: 上层TLS PDU中包括下层TCP协议的一些控制信息
- MAC采用数据: 类型type、seq、data、 M_c 来计算
- $MAC = MAC(M_c, \text{sequence} || \text{type} || data)$



Security: 8-76

t-tls: 过程

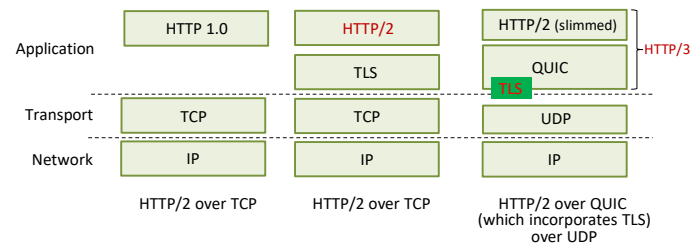


t-tls: 并不完整

- 字段多长?
- 那种加密算法?
- 希望提供协商机制, 允许客户端和服务端支持不同的加密套件, 在数据传输之前**协商和选择**特定的套件
 - 密钥生成算法-用什么算法生成双方采用的加密密钥和MAC密钥
 - 加解密算法 (和长度)
 - MAC算法 (和长度)
 - 数字签名算法 (对应上例中的Hash算法)

Transport-layer security (TLS)

- TLS提供API, 可为任何应用使用
- HTTP视角下的TLS



TLS 1.3 和QUIC之间的协作关系:

- 1) TLS借助QUIC交换报文
- 2) QUIC借助TLS协商加密套件和交换密钥、认证、加密

TLS: 加密套件

- “加密套件”: 密钥生成算法, 加密算法, MAC算法, 数字签名算法
 - TLS协议并不捆绑固定的具体算法
- TLS: 1.3 (2018): 提供比TLS 1.2 (2008) 支持更少的加密套件 (防止降级攻击)
 - TLS 1.3只有**5个套件选择**, 而不是TLS 1.2的37个
 - 采用**Diffie—Hellman (DH)** 算法进行**密钥交换**, 而不仅仅是RSA
 - **加密认证**算法: 加密同时进行认证, 而不是加密之后再认证的分离算法
 - **HMAC**采用SHA (256或者284) 加密散列函数-主要用于报文的完整性 (和可认证性)
 - HMAC: 用Hash做MAC (当然要secret加入运算, 即 M_C)

TLS 加密套件

密码套件的名称和其安全性属性的示例

密码套件名称	身份验证	密钥交换	密码	MAC	PRF
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256	RSA	ECDHE	AES-128-GCM	—	SHA256
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384	ECDSA	ECDHE	AES-256-GCM	—	SHA384
TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA	RSA	DHE	3DES-EDE-CBC	SHA1	协议
TLS_RSA_WITH_AES_128_CBC_SHA	RSA	RSA	AES-128-CBC	SHA1	协议
TLS_ECDHE_ECDSA_WITH_AES_128_CCM	ECDSA	ECDHE	AES-128-CCM	—	SHA256



https://blog.csdn.net/m0_37621078/article/details/106028622

Security: 8- 81

SSL&TLS个版本支持的秘钥交换、协商和认证情况

Algorithm	SSL 2.0	SSL 3.0	TLS 1.0	TLS 1.1	TLS 1.2	TLS 1.3	Status
RSA	Yes	Yes	Yes	Yes	Yes	No	
DH-RSA	No	Yes	Yes	Yes	Yes	No	
DHE-RSA (forward secrecy)	No	Yes	Yes	Yes	Yes	Yes	
ECDSA	No	No	Yes	Yes	Yes	No	
ECDSA-RSA (forward secrecy)	No	No	Yes	Yes	Yes	Yes	
DH-DSS	No	Yes	Yes	Yes	Yes	No	
DHE-DSS (forward secrecy)	No	Yes	Yes	Yes	Yes	No ^[48]	
ECDSA-ECDSA	No	No	Yes	Yes	Yes	No	
ECDSA-ECDSA (forward secrecy)	No	No	Yes	Yes	Yes	Yes	
PSK	No	No	Yes	Yes	Yes		Defined for TLS 1.2 in RFCs
PSK-RSA	No	No	Yes	Yes	Yes		
DHE-PSK (forward secrecy)	No	No	Yes	Yes	Yes		
ECDSA-PSK (forward secrecy)	No	No	Yes	Yes	Yes		
SRP	No	No	Yes	Yes	Yes		
SRP-DSS	No	No	Yes	Yes	Yes		
SRP-RSA	No	No	Yes	Yes	Yes		
Kerberos	No	No	Yes	Yes	Yes		
DH-ANON (insecure)	No	Yes	Yes	Yes	Yes		
ECDSA-ANON (insecure)	No	No	Yes	Yes	Yes		

https://blog.csdn.net/m0_37621078/article/details/106028622

Security: 8- 82

真实TLS：握手(1)

目标

1. 服务器认证（客户端认证服务器的身份）
2. 协商加密套件：就加密算法、MAC算法等协商一致
3. 双方按照约定根据nonces等导出会话秘钥
 - a. 加解密使用的key
 - b. MAC使用的key
4. 客户端认证（可选项）

Security: 8- 83

TLS 1.3:快速握手-Diffie-Hellman算法

客户端传到服务器

p(素数, 如97)和g (p的原根, 如5)

随机生成a(36)

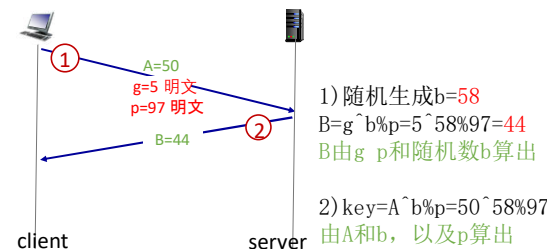
$A = g^a \pmod p = 5^{36} \pmod{97} = 50$

A由g, p和随机a算出

计算对称秘钥

$key = B^a \pmod p = 44^{36} \pmod{97} = 75$

由B和a, 以及p算出



共享Key= $g^{ab} \pmod p$
1-RTT就可以通信

Security: 8- 84

2025中科大高网



2025中科大高网

- Security: 8- 87



密钥导出

2025中科大高网

- 客户端不重数、服务器不重数和pre-master secret (PMS) 输入到随机生成器
 - 产生出主密钥MS
- 主密钥MS和nonces 输入到另外一个随机数生成器: “key block”
- key 块被切分, 再切分
 - client encryption key
 - server encryption key
 - client MAC key
 - server MAC key
 如果采用: 3DES或者AES, 还生成
 - client initialization vector (IV)
 - server initialization vector (IV)

8: Network Security

89

真实的TLS: 握手(3)

2025中科大高网

最后两步: 保护握手阶段防止篡改

- 客户端通常提供一系列算法: 有的很强, 有的弱
- 中间人可能会从列表中删除比较强的加密算法 (算法列表是明文传输的)
- 为了防止这种攻击, 对于所有握手报文交换作MAC (最后2步: 5, 6)
 - 客户端将握手阶段所有报文的MAC发送给服务器, 便于服务器检查有无篡改
 - 同样, 服务器将所有报文的MAC发送给客户端, 便于客户端检查有无篡改
 - 而且最后2个报文都是加密的

Security: 8- 90

真实的TLS: 握手(3)

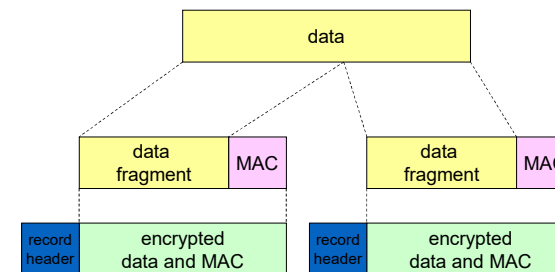
2025中科大高网

- 为什么2个随机的不重数 (客户端和服务器的)?
 - 防止重放攻击
- 假设Trudy嗅探到Alice和Bob的所有报文, Bob这一侧不变化
- 第二天, Trudy和Bob建立TCP连接, 发送同样的记录序列 (重放攻击: 伪造Alice对Bob进行重放)
 - 如果密钥只依赖于Alice一侧的nonce, 2次会话生成的密钥都一样
 - Bob (Amazon) 可能会认为Alice提交了关于一个物品的2个订单
 - 解决: Bob在每个会话上也发送不同的随机不重数, 这导致2次会话的加密密钥不一样
 - Trudy的重放攻击报文无法通过完整性校验

Security: 8- 91

TLS 记录格式

2025中科大高网



record header: content type; version; length

MAC: includes sequence number, MAC key M_x

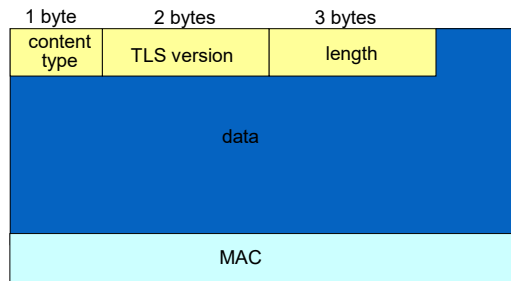
fragment: each TLS fragment 2^{14} bytes (~16 Kbytes)

8: Network Security

92

TLS 记录格式

2025中科大高网

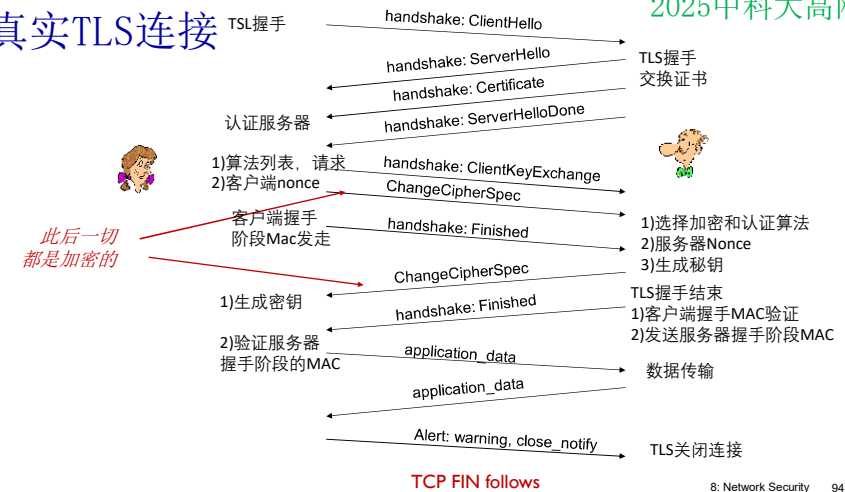


数据和MAC都是被加密的(对称算法)

93

真实TLS连接

2025中科大高网



第八章 提纲

2025中科大高网

- 什么是网络安全?
- 加密原理
- 认证, 报文签名, 报文完整性, 共享密钥协商
- 安全电子邮件
- 使TCP连接安全: TLS
- **网络层安全性: IPSec**
- 无线和移动网络的安全
- 实践中的网络安全: 防火墙和IDS



Security: 8-95

IPSec协议: 位置

2025中科大高网

- **在2个网络实体(主机或路由器)之间提供安全性**
- IP之上、传输层协议之下
- 发送实体加密数据报载荷, 载荷可以是:
 - 原IP的所有载荷都可以是IPSec的载荷
 - TCP段、UDP数据报、ICMP报文、OSPF报文等
- 层次较低, 所有从发送端实体到其他接收方的数据都可以被隐藏
 - web pages, e-mail, P2P文件传输, TCP SYN 分组 ...
- **“地毯覆盖”**
 - IP的载荷(如TCP段)是经过加密, 认证, 完整性检查的

Security: 8-96

IP Sec: 特性和组成

- 安全性: 机密性、完整性、可认证性、重放攻击保护
- 2个IPSec子协议

Authentication Header (AH) 协议 [RFC 4302]

提供源端的可认证性和数据完整性, 但是不提供机密性

Encapsulation Security Protocol (ESP) [RFC 4303]

提供源端可认证性, 数据完整性和机密性
比AH用的广泛

Security: 8- 97

IP Sec的2个模式



传输模式:

- 主机之间
- 只有数据报载荷被加密和认证 (头部是明文传输的)

隧道模式:

- 路由器之间
- 整个数据报都被加密和认证
- 加密的数据报被封装在一个新的数据报中, 新的IP头部
- 2个路由器之间就像有个隧道一样, 将2个网络连接起来: VPN

Security: 8- 98

IP Sec: 模式和协议的组合

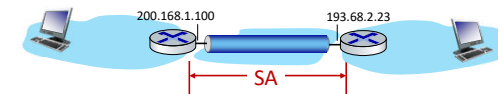
Host mode with AH	Host mode with ESP
Tunnel mode with AH	Tunnel mode with ESP

最常用, 最重要

Security: 8- 99

安全关联Security associations (SAs)

- 在发送数据之前, 要在发送实体和接收实体之间建立 “安全关联(SA)”
 - SA: 一个方向一个安全关联
 - 单向安全数据通信的关系
- 发送端、接收端实体维护SA的状态信息
 - 维护通信的状态
 - 回顾: TCP端结点也维护了状态信息
 - IP是无连接的; IP-sec是面向连接的 (不是有连接的) !
- VPN一共有多少个SA? 一个总部, 一个分支和n个旅行中的销售。
 - $2+2n$

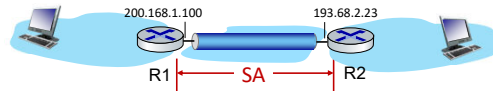


Security: 8- 100

安全关联 (SAs)

R1为SA存储:

- 32-bit identifier: *Security Parameter Index (SPI)*
- 源SA接口 (200.168.1.100)
- 目标SA接口 (193.68.2.23)
- 采用的加密类型(e.g., 3DES with CBC)
- 加密的密钥
- 完整性校验算法(e.g., HMAC with MD5)
- 认证的key: MAC key



Security: 8-101

Security Association Database (SAD)

- ❖ 端结点（路由器或主机）将SA的状态维护在 *security association database (SAD)*，可以使用它们在处理过程中访问到所用的信息
- ❖ 公司有n个销售，在R1的SAD中有 $2 + 2n$ 个SA
- ❖ 当发送IPsec数据报时，R1访问SAD来决定如何处理该数据报
- ❖ 当IPsec数据报到达R2时，R2检查IPsec数据报的SPI，用该值检索SAD，对应地处理该数据报
 - 解密、完整性检查和可认证性检查

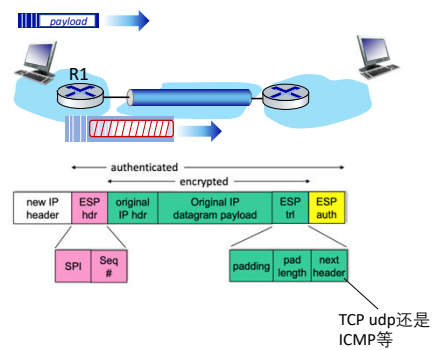
SAD: "how" to do it

8: Network Security-2

102

ESP 隧道模式: R1动作

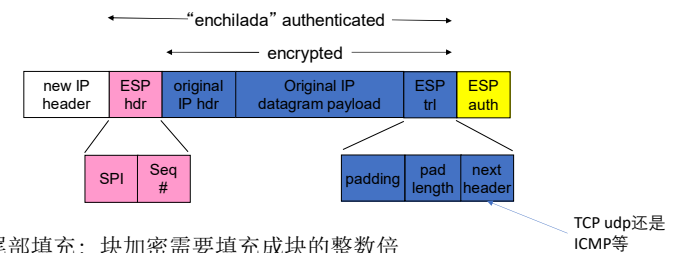
ESP、隧道模式



8: Network Security-2

103

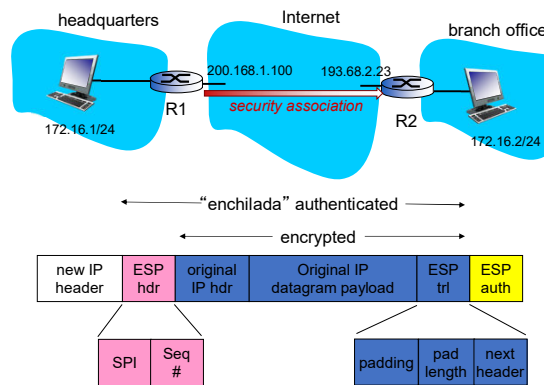
R1的动作: IP数据报封装在IPSec中



- ESP尾部填充: 块加密需要填充成块的整数倍
- 加密整个数据报 (包括尾部)
- 增加ESP头部:
 - SPI: 让接收实体知道如何处理
 - 序号: 防止重放攻击
- 计算并添加ESP中的MAC认证字段, 采用共享密钥创建

8: Network Security-2 104

R1的动作:IP数据报封装在IPSec中



1. 在原始数据报（包括原始数据报的头部字段）的尾部附加“ESP尾部”字段
2. 采用SA指定的算法和key加密以上结果
3. 将被加密部分的前面，插入ESP头部，创建“enchilada”
4. 对全部的“enchilada”创建鉴别MAC，采用SA中指定的算法和key，在**整个分组**后面附上MAC，形成新IP分组载荷
5. 创建新IP头部，包括典型IPv4的头部字段，插在载荷的前面
 - 协议字段：50，标识 ESP来处理
 - 新分组：源IP R1，目标IP R2

105

IPsec 序号

- 对于一个新的SA，发送端初始化该序号为0
- 每一次在SA上发送新数据报
 - 发送方增加序号的值
 - 将该序号值放入seq #字段中
- 目标：
 - 阻止嗅探和重放攻击
 - 如果接收到重复的，经过认证的IP数据报可以中断服务
 - 攻击者只改序号是不行的，经过认证的，对应的MAC字段也需要修改
- 方法：
 - 目标端检查重复
 - 不维护所有接收到分组的状态，而是采用窗口范围内的检查

106

IPSec服务安全性分析

- 假设Trudy在R1和R2之间，她不知道keys.
 - Trudy能够看到数据报的原始内容吗？源IP、目标IP地址，传输层协议，应用端口号能够探知吗？
 - 原始数据报加密，IP地址，端口号信息不可探知
 - 可以更改其中的某些bits，而且不被检测到吗？
 - 序号在IPSec分组中，尾部有MAC完整性检查机制
 - 伪装成R1，采用R1的IP地址呢？
 - 也通不过完整性检查，没办法形成正确的MAC
 - 重放一个数据报呢？
 - 有序号，通不过完整性检查

107

Security Policy Database (SPD)

- **策略**：给定一个数据报，发送实体知道它是否该使用IPsec，还是普通IP数据报
- 也需要知道采用哪个SA关联，获取其配置数据
 - 可能会使用：源和目标的IP地址，协议号
- 在SPD中的信息指示：对于到来的数据报到底**要不要**IPsec的处理
- **SAD**中的信息指示：**如何做**
 - 按照SAD具体参数对进出的数据报进行IPSec的处理

108

IKE: Internet Key Exchange

- 前面的例子: 在IPsec端节点上手工设置IPsec SA:

Example SA

SPI: 12345
 Source IP: 200.168.1.100
 Dest IP: 193.68.2.23
 Protocol: ESP
 Encryption algorithm: 3DES-cbc
 HMAC algorithm: MD5
 Encryption key: 0x7aeaca...
 HMAC key: 0xc0291f...

- 手工设置这些key对于100s端节点的VPN来说是不切实际
- IPsec IKE (Internet Key Exchange): 自动建立SA**
 - 交换证书(认证), 协商: 鉴别和加密算法
 - 交换用于生成Key的信息, 生成keys
 - 建立SA

109

IKE: 阶段1

- 条件: 如果双方没有建立起VPN的**管理连接IKE SA**
- 目的: 建立**管理连接IKE SA**(双向, 不同于SA)
 - 安全参数协商(加密算法, MAC算法)
 - 密钥生成(HF算法), 双方共享IKE SA的密钥
 - 相互认证对方(对称方式, RSA非对称方式)
- 模式: 主模式和侵略模式(贪婪模式)
 - 主模式提供身份保护, 更加弹性化
 - 贪婪模式采用更少的报文, 更快

110

IKE: 阶段2

- 目的: 在阶段1建立的IKE SA基础上, 安全地建立2个**数据连接SA**(2个单向)
- 结果:
 - 协商加密算法, 鉴别算法
 - 建立加密密钥, 鉴别密钥
 - 周期性的对数据连接进行**密钥更新**
 - 无需认证

IKE: PSK and PKI

- 相互认证对方身份(证明你是谁)
 - pre-shared secret (PSK), 对称加密体系
 - public/private keys and certificates (PKI), 公开密钥加密体系
- PSK: 双方都从一个共享的secret开始
 - 运行IKE来认证对方, 而且建立起 IPsec SAs (每个方向一个), 包括加密和认证的keys
- PKI: 双方开始于public/private key 对和证书
 - 运行IKE来相互认证对方, 获得 IPsec SAs (每个方向一个)
 - 和SSL握手类似

Security: 8-112

IPsec 总结

- IKE交换报文用于：认证身份，协商算法（加密套件：加密算法和报文鉴别算法），生成和交换keys，生成SPI，自动建立SA
- AH或者ESP协议
 - AH提供完整性，源端的可认证性
 - ESP（相对于AH来说）提供附加的机密性
- IPsec对可以是2个网络实体间的安全通信关系
 - 2个路由器/防火墙
 - 1个路由器/防火墙，另外一个端系统是
 - 2个端系统之间

113

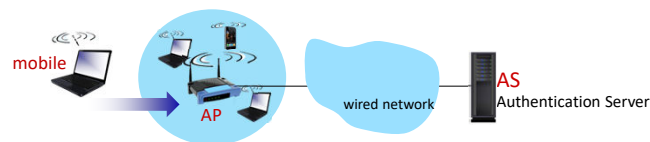
第八章 提纲

- 什么是网络安全？
- 加密原理
- 认证，报文签名，报文完整性，共享密钥协商
- 安全电子邮件
- 使TCP连接安全：TLS
- 网络层安全性：IPSec
- 无线和移动网络的安全
 - 802.11 (WiFi)
 - 4G/5G
- 实践中的网络安全：防火墙和IDS



Security: 8-114

802.11: 认证、加密

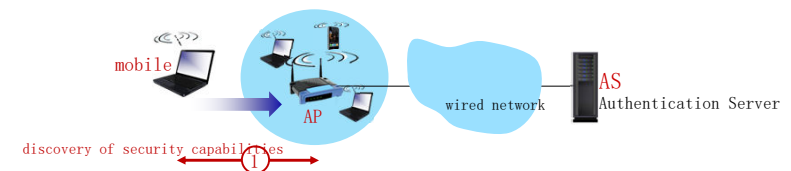


到来的移动设备（客户端）必须：

- 和AP建立关联：在无线链路上（建立）通信关系
- 执行移动设备与网络的双向认证
- 导出密钥：用于在认证期间和之后，加密空中传输的帧（例如：认证和用户数据帧传输）

Wireless network security 115

802.11: 认证、加密



① 安全能力的发现，建立通信关系：

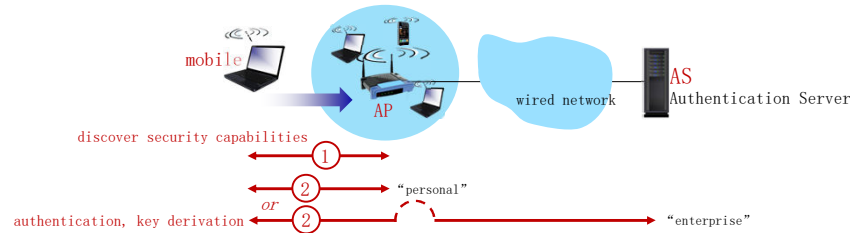
- AP通过信标帧通告其存在，或者设备发送探测帧、AP给出回应
- AP发送它能够提供的认证和加密形式
- 设备向AP请求它期望的认证、加密具体形式

初始的信息交换：设备没有被认证，加密的密钥双方还没有生成出来

Wireless network security 116

802.11: 认证、加密

2025中科大高网



② 双向认证以及共享对称密钥的导出:

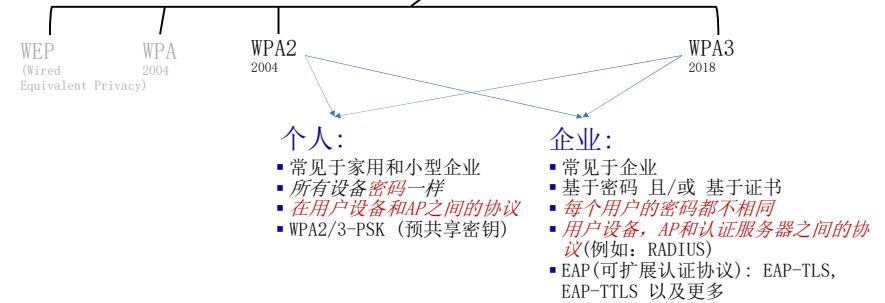
- 前提: AS、移动设备可能已经拥有了共享密钥 (例如: 共享密码)
- 使用共享密码、nonces (防重放攻击)、加密散列 (保证完整性) 来
 - 双向认证对方
 - 导出对称式的密钥 (例如AES密钥)

Wireless network security 117

WiFi 安全标准: 个人的, 企业的

2025中科大高网

WPA (WiFi Protected Access) 安全性



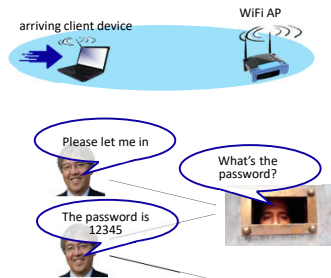
Wireless network security 118

WiFi 安全性: 基础设施

2025中科大高网

个人

- 在用户设备和AP之间
- WPA2/3-PSK: 用户设备和AP知道密码



企业

- 主要在用户设备和认证服务器之间 (AP扮演成一个中转角色, 认证者)



Wireless network security 119

WPA2-PSK (预共享密钥)-personal

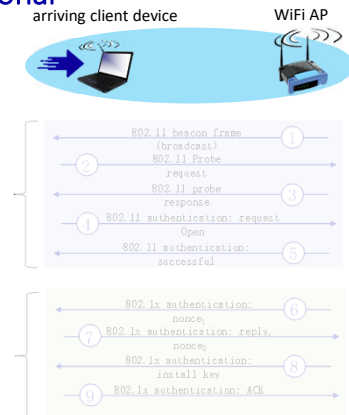
2025中科大高网

- 为所有设备配置的相同密码被存储在AP上
- 所有设备预先知密码 (“预共享密钥PSK”)

802.11 打开 “authentication”:
客户设备与AP建立关联
(尚未进行实际的“认证”)

WPA2-PSK的2个“阶段”

802.1x WPA2/3-PSK: 1) 认证;
2) 生成新的AES会话加密密钥



Wireless network security 120

WPA2-PSK: 阶段 1 (建立关联)

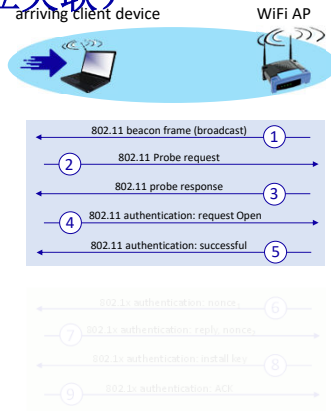
2025中科大高网

- ① AP广播802.11信标帧 (packet 1 in Wireshark trace*)
- ② 客户终端发送 802.11 探测请求 (packet 2)
- ③ AP用802.11探测回复帧应答 (packet 3)
- ④ 客户终端发送 802.11 认证帧, 请求打开系统, i.e., 无密码认证 (packet 4)
- ⑤ AP用802.11认证帧回复 (packet 5), 带状态码: “成功”

... 此时, “真实”身份验证尚未发生!

* http://gaia.cs.umass.edu/kurose/carioca_iphone_association_selected_packets_onlyV2.pcapng

Wireless network security 121

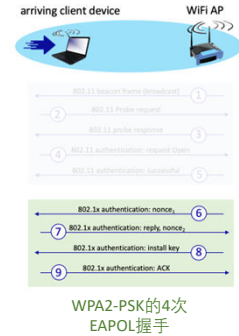


WPA2-PSK: 阶段 2-4次握手进行认证、导出密钥

2025中科大高网

EAPOL: Extensible Authentication Protocol over LAN

- 阶段1: 客户端和AP已建立起了802.11会话 (不安全), 且都知道共享密码
- 4次 EAPOL握手: 采用共享密码、nonces为这次会话生成新的一次性会话密钥, 技术:
 - 共享密码: 用于加密EAPOL报文, 以及提供EAPOL的报文完整性 (MIC), 同时认证对方
 - nonces: 确保活跃, 重放攻击保护
 - 新的、一次性的AES会话密钥: 防止对共享密码的暴力解密攻击 (虽然预共享密码都一样, 但是每个客户端接入后使用不同的对称密钥)



Wireless network security 122

WPA2-PSK: 阶段 2-4次握手进行认证、导出密钥

2025中科大高网

- ⑥ AP 发送 802.1x EAPOL 报文: WPA2-PSK (aka RSN), nonce₁ (packet 6 in Wireshark trace*)
- ⑦ 客户用PSK和nonce₁, 生成应答用于被AP认证 (包含MIC, 保证报文完整性), 还生成、发送 nonce₂ (packet 7)
- ⑧ 1) AP检查回复和MIC (认证客户端, 检查完整性); 2) 将对nonce₂的应答 (带MIC) 发送给客户端 (packet 8); 3) 用PSK生成新的会话密钥
- ⑨ 1) 客户端检查AP的回复及MIC (认证AP); 2) 发送 ACKs (packet 9); 3) 安装AES会话密钥... 双方就绪!

... 此时, 客户端和AP独立按照约定生成会话AES密钥, 该密钥没有被传过

(PSK, SSID) -> 配对主密钥PMK

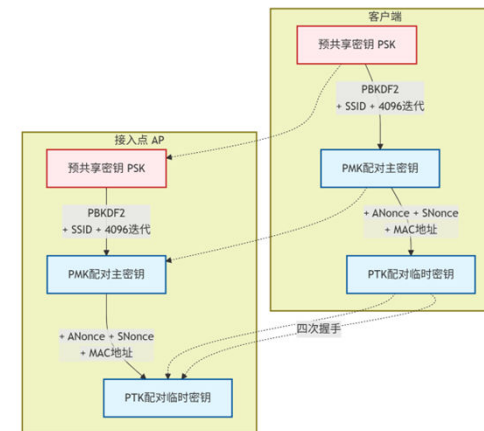
PMK+2个nonces -> PTK, PTK包括AES会话密钥

* http://gaia.cs.umass.edu/kurose/carioca_iphone_association_selected_packets_onlyV2.pcapng

Wireless network security 123



2025中科大高网



Security: 8-124

WPA3-personal

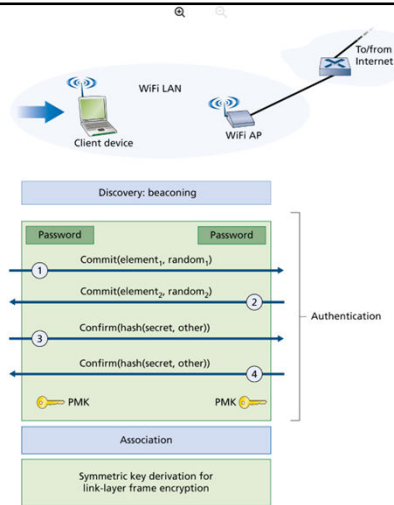
1. 双向认证

- ① 客户端commit:
 - 共享密钥生成的element1 (random1加入计算且反向计算难), random1
- ② AP确认客户端知道共享密码, 发送commit:
 - 共享密钥生成的element2, random2
- ③ 客户端确认AP知道密钥, 发送confirm: 之前所有报文的hash, 完整+防重放
- ④ AP确认客户端收到所有的报文, 发送confirm报文, 所有报文hash, 完整+防重放
 - 客户端验证报文完整性

2. 生成配对主密钥PMK:

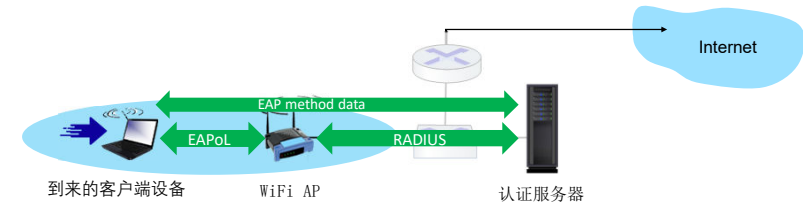
- PMK=f(共享密码, random1, random2, ...)
- 每个客户端加入网络都有不同PMK

3. 用PMK生成链路层加密密钥PTK



802.1x 企业 认证框架

2025中科大高网



客户端

客户端设备需要被认证, 然后被允许访问网络

认证者

在客户端和认证服务器之间中继报文来认证客户端, 授权客户端使用WLAN

认证服务器

具有客户端身份验证和访问权限信息的服务器、

802.1x企业术语

Wireless network security 126

802.1x 企业: Extensible Authentication Protocols: EAPs

2025中科大高网

- EAP 主要在客户端和认证服务器之间 (e.g., RADIUS 服务器)
- AP 主要充当传递者
- 凭据被存储在客户端和认证服务器上



- ~40 不同的EAP 协议(!)

- 差异主要在凭证: 密码, 证书, SIM卡, 令牌...
- 经常使用的是: EAP-MD-5, EAP-TLS, EAP-PEAP, EAP-TTLS, EAP-Fast, and Cisco LEAP. EAP-MD-5



Wireless network security 127

EAP-TTLS: 隧道化的TLS [RFC 5281]

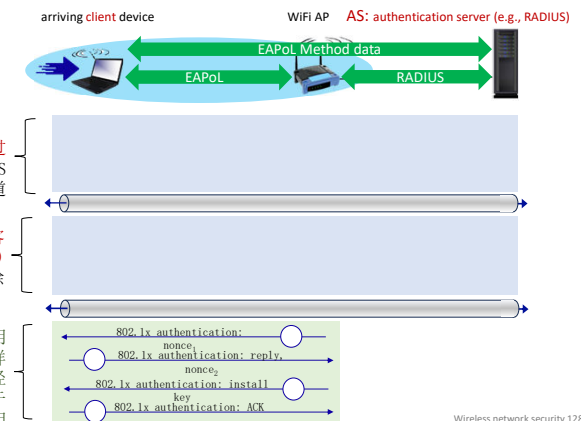
2025中科大高网

EAP-TTLS的 2 “阶段”

阶段 1: 客户端认证AS (如: 通过服务器的公钥), 在客户端和AS之间建立TLS隧道

阶段 2: 在加密隧道中AS认证客户端 (如: 通过客户端的密码) 之后隧道被拆除

4次 EAPoL握手用于生成会话密钥 就像在WPA2-PSK中一样 (不是用于身份认证, 在阶段1和2已经做过双向身份认证了, nonces主要用于和阶段2生成的PMK来生成对称AES密钥)



Wireless network security 128

2025中科大高网

-
- arriving client device
- WiFi AP
- AS: authentication server
(e.g., RADIUS)
- 1 EAPOL Start
- 2 802.11 Request, Identity
- 3 EAPOL Response, Identity
- 4 RADIUS access request
- 5 EAP-TTLS: Response: Start
- 6 EAP-TTLS Response: client Hello, nonce, ciphersuite
- 7 EAP-TTLS Request: server Hello, nonce, server cert, ciphersuite
- 8 EAP-TTLS Response: client key info, Finished
- 9 EAP-TTLS Request: Finished
- set up TLS tunnel
- Phase 2
- Wireless network security

2025中科大高网

The diagram illustrates the 802.11 authentication process between a client (laptop) and an Access Point (AP) within a wireless network. The process is divided into two main phases: Authentication and Association.

Authentication Phase:

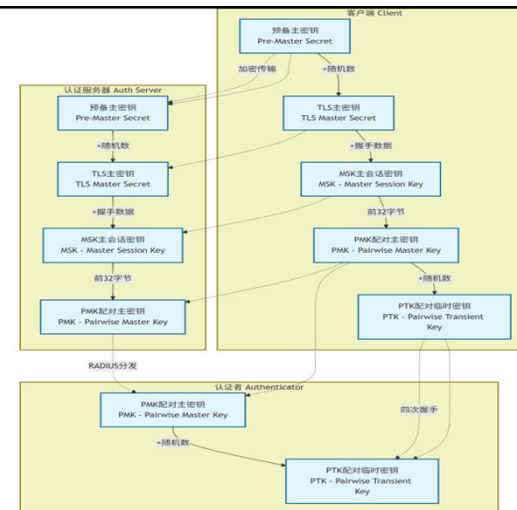
- 1** The client sends an **EAPOL Start** message to the AP.
- 2** The AP responds with an **802.11 Request, Identity** message.
- 3** The client responds with an **EAPOL Response, Identity** message.
- 4** The AP sends a **RADIUS access request** to the RADIUS server.
- 5** The RADIUS server responds with **EAP-TTLS: Response: Start** to the AP.
- 6** The AP sends an **EAP-TTLS Response: client Hello, nonce, ciphersuite** to the client.
- 7** The client responds with an **EAP-TTLS Request: server Hello, nonce, server cert, ciphersuite** to the AP.
- 8** The AP sends an **EAP-TTLS Response: client key info, Finished** to the client.
- 9** The client sends an **EAP-TTLS Request: Finished** message to the AP.

Association Phase:

After the authentication phase, the client sends an **802.11 Request, Association** message to the AP. The AP then responds with an **802.11 Response, Association** message, indicating that the client is now associated with the network.

2025中科大高网

下一步: 客户端和AP各自拥有了PMK, 各自通过EAPoL 4次握手协商信道的
PTK=F (PMK, nonce1, nonce2), PTK中有AES
密码
之后可以客户端可以运行DHCP



EAP-TTLS认证成功



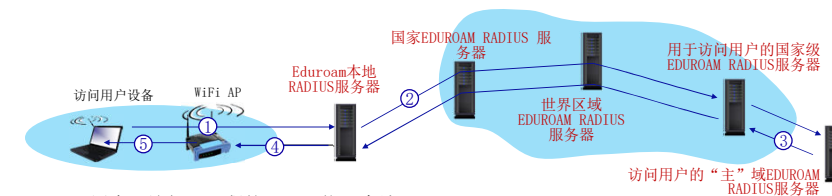
MSK (64字节)



PMK (前32字节) → 四次握手 → PTK (加密无线数据)

Security: 8-133

本地认证服务器可能使用代理



Wireless network security 134

第八章 提纲

- 什么是网络安全？
- 加密原理
- 认证，报文签名，报文完整性，共享密钥协商
- 安全电子邮件
- 使TCP连接安全：TLS
- 网络层安全性：IPSec
- 无线和移动网络的安全
 - 802.11 (WiFi)
 - 4G/5G
- 实践中的网络安全：防火墙和IDS



Security: 8-135

4G LTE中的认证和加密



- 到来的移动设备M必须：
 - 和基站BS建立关联：通过4G无线链路通信
 - 双向认证：移动终端M被网络认证，以及移动设备M认证网络
- 与WiFi明显的差别：
 - 有归属网络，访问网络的概念
 - 移动设备的SIM卡：提供全局的身份标识ISMI，存储了共享keys
 - 全局身份标识的层次性：所在home network，自身标识ID
 - 在被访问网络(visited network)中的服务取决于在归属网络(home network)中订购的业务

Security: 8-136

2025中科大高网

4G LTE中的认证和加密

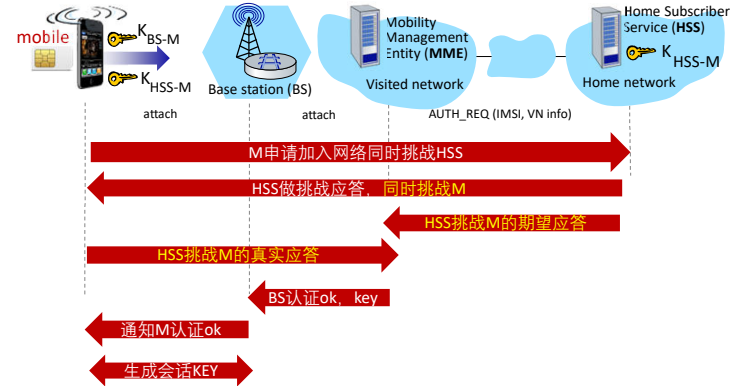


- 移动设备、BS采用导出的会话密钥 K_{BS-M} 在4G链路上加密通信数据
- 被访网络中的MME+归属网络中HSS，共同扮演了WiFi中AS的角色
 - 最终认证设备是：HSS
 - 被访网络visited network和归属网络home network之间有着信任关系和商业关联

Security: 8-137

2025中科大高网

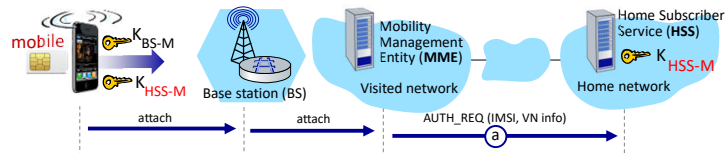
4G LTE中的认证和加密



Security: 8-138

2025中科大高网

4G LTE中的认证和加密



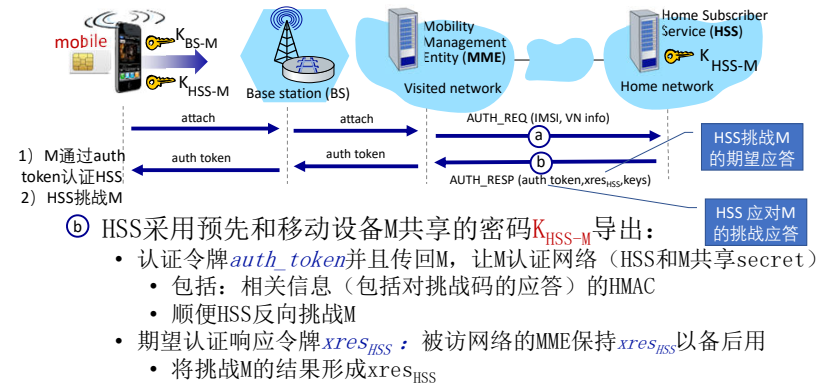
a 认证请求发出，到达归属网络的HSS

- 移动设备发送附加报文attach（包括它所在的IMSI-国际移动用户识别码，被访网络的信息VN）从BS中继到被访MME，最终到达HSS
- IMSI有结构，包含了移动终端归属网络home network的标识
- 最终可以路由到移动设备M的归属网络的HSS

Security: 8-139

2025中科大高网

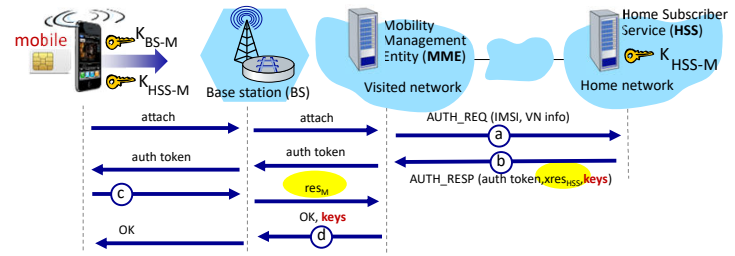
4G LTE中的认证和加密

b HSS采用预先和移动设备M共享的密码 K_{HSS-M} 导出：

- 认证令牌 $auth_token$ 并且传回M，让M认证网络（HSS和M共享secret）
 - 包括：相关信息（包括对挑战码的应答）的HMAC
 - 顺便HSS反向挑战M
- 期望认证响应令牌 $xres_{HSS}$ ：被访网络的MME保持 $xres_{HSS}$ 以备后用
 - 将挑战M的结果形成 $xres_{HSS}$

Security: 8-140

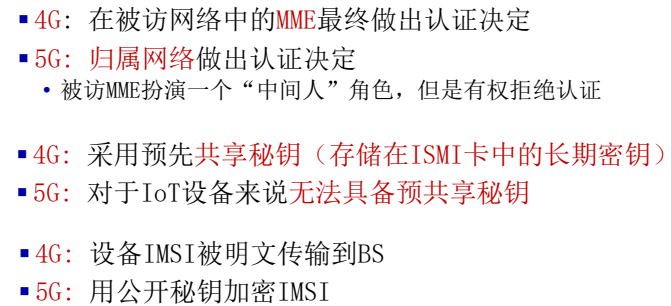
4G LTE中的认证和加密



- ④ M被网络认证:
- MME比较移动设备计算的 res_M 的和HSS计算的 $xres_{HSS}$, 如匹配, M认证成功
 - MME通知BS: 移动设备M被认证通过, 为BS生成keys

Security: 8- 142

认证和加密：从4G到5G



Security: 8- 144

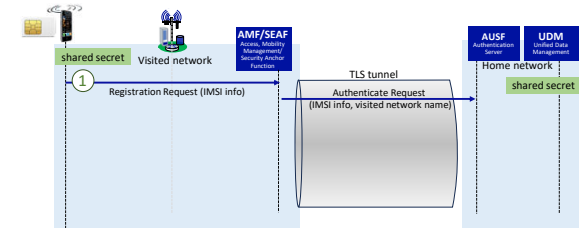
5G中的认证和加密



- 到来的移动设备UE必须：
 - 与BS关联：在无线链路上（建立）通信
 - 双向认证：向网络认证自己的身份，以及认证网络
- 和WiFi有明显差别
 - 5G网络中的UE有归属网络的概念
 - UE的SIM卡内置了全球身份信息ISMI，包括与HSS-M的共享密钥
 - 被访问网络的服务（付费的）依赖于UE归属网络的服务订购套餐情况

Wireless network security 145

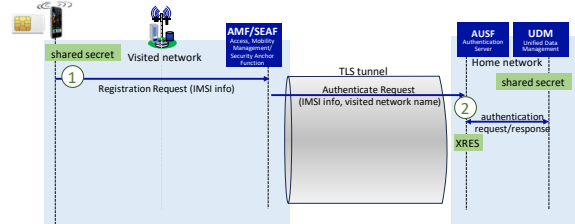
5G中的认证和加密



- UE向被访问网络的AMF发送带有身份（IMSI）信息的注册请求消息
- 被访问网络的AMF定位设备中的所在归属网络AUSF，和归属AUSF建立TLS隧道（所有的报文都被认证和加密）

Wireless network security 146

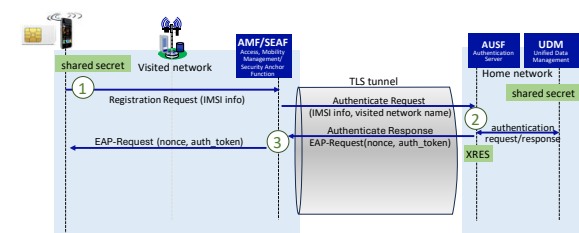
5G中的认证和加密



- 归属AUSF联系归属的UDM
- 归属UDM创建一个认证向量（向UE证明是归属UDM创建的令牌，并且报文完整）
 - 随机数nonce
 - 认证令牌auth_token：是UE的长期密码、nonce、还有其他信息的综合，可以向UE证明是归属UDM产生的
 - 签名MIC：保证报文的完整性
 - XRES：UE将要计算出来（依赖于nonce）的响应

Wireless network security 147

5G中的认证和加密



- 归属AUSF向访问网络中的AMF发送认证令牌以及nonce，AMF转发给UE

Wireless network security 148

The diagram illustrates the EAP-TLS authentication process across two networks: a Visited network and a Home network.

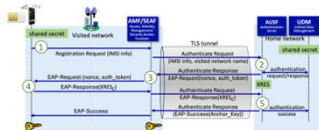
- Visited network:** Contains an **AMF/SEAF** (Access and Mobility Management Function / Security Anchor Function) and a **shared secret** (represented by a green box).
- Home network:** Contains an **AUSF** (Authentication Server Function) and a **UDM** (Unified Data Management).
- Authentication Process:**
 - The **AMF/SEAF** sends a **Registration Request (IMSI info)** to the **AMF/SEAF** in the Visited network (labeled 1).
 - The **AMF/SEAF** sends an **Authenticate Request (IMSI info, visited network name)** to the **AMF/SEAF** in the Visited network (labeled 2).
 - The **AMF/SEAF** sends an **EAP-Request (nonce, auth_token)** to the **AMF/SEAF** in the Visited network (labeled 3).
 - The **AMF/SEAF** sends an **EAP-Response (XRES)** to the **AMF/SEAF** in the Visited network (labeled 4).
 - The **AMF/SEAF** sends an **Authenticate Request (nonce, auth_token)** to the **AMF/SEAF** in the Visited network (labeled 5).
 - The **AMF/SEAF** sends an **Authenticate Response** to the **AMF/SEAF** in the Visited network (labeled 6).
 - The **AMF/SEAF** sends an **EAP-Response (XRES)** to the **AMF/SEAF** in the Visited network (labeled 7).
 - The **AMF/SEAF** sends an **EAP-Response (XRES)** to the **AMF/SEAF** in the Visited network (labeled 8).
 - The **AMF/SEAF** sends an **EAP-Response (XRES)** to the **AMF/SEAF** in the Visited network (labeled 9).
 - The **AMF/SEAF** sends an **EAP-Response (XRES)** to the **AMF/SEAF** in the Visited network (labeled 10).
- Security:** The communication between the Visited network and the Home network is protected by a **TLS tunnel**.
- Authentication:** The **AUSF** in the Home network performs **authentication request/response** (labeled 2).
- Shared Secret:** A **shared secret** (represented by a green box) is used for authentication in the Home network.
- XRES:** The **XRES** (XRES) is sent from the **AMF/SEAF** in the Visited network to the **AMF/SEAF** in the Visited network (labeled 4).

- ④

5

- Wireless network security 150

2025中科大高网



- Wireless network security 151

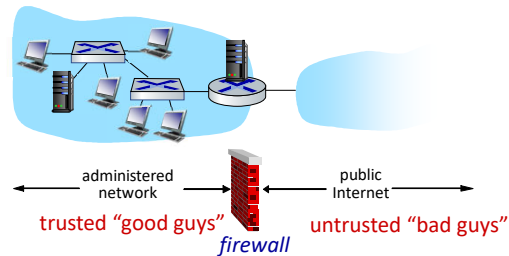
2025中科大高网

-

防火墙

firewall

将组织内部网络和互联网络隔离开来，按照规则允许某些分组通过（进出），或者阻塞掉某些分组



Security: 8-153

防火墙：必要性

阻止拒绝服务攻击：

SYN flooding: 攻击者建立很多伪造TCP连接，对于真正用户而言由于服务器的资源被耗尽，他们的访问被拒绝

阻止非法的修改/对非授权内容的访问

○ e. g., 攻击者替换掉CIA的主页

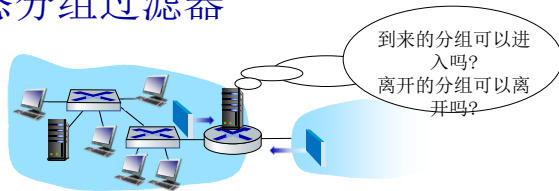
只允许认证的用户能访问内部网络资源（经过认证的用户/主机集合）

2种类型的防火墙：

- 无状态分组过滤器
- 有状态分组过滤器
- 应用网关

Security: 8-154

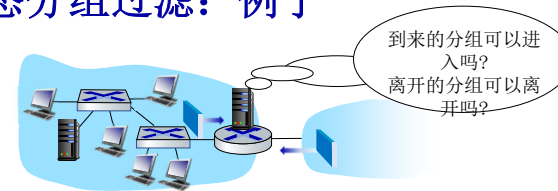
无状态分组过滤器



- 内部网络通过**配置防火墙的路由器**连接到互联网上
- 路由器对分组逐个过滤，根据分组相应字段匹配到规则相应自字段来决定转发还是丢弃
 - 源IP地址，目标IP地址
 - TCP/UDP源和目标端口
 - ICMP报文类别
 - TCP SYN 和ACK bits

Security: 8-155

无状态分组过滤：例子



- **例1:** 阻塞进出的数据报：只要拥有IP协议字段 = 17，而且源/目标端口号 = 23.
 - **结果:** 所有的进出UDP流 以及TCP 上telnet连接分组都被阻塞掉
- **例2:** 阻塞进入内网的TCP段：它的ACK=0.
 - **结果:** 阻止外部客户端主动和内部网络的主机建立TCP连接，但允许内部网络的客户端主动和外部服务器建立TCP连接

Security: 8-156

无状态分组过滤器：更多例子

策略	防火墙设置
不允许外部的web进行访问	阻塞掉所有外出具有目标端口80的IP分组
不允许来自外面的TCP连接，除非是机构公共WEB服务器的连接	阻塞掉所有进来的TCP SYN分组，除非130.207.244.203, port 80
阻止Web无线电占用可用带宽.	阻塞所有进来的UDP分组 - 除非 DNS 和路由器广播
阻止你的网络被smurf DoS所利用	阻塞掉所有到达广播地址 (130.207.255.255) 的ICMP分组.
阻止内部网络被tracerout，从而得到你的网络拓扑	阻塞掉所有外出的 ICMP TTL过期的流量

Security: 8-157

Access Control Lists

ACL: 规则的表格，自动向下和输入的分组合进行匹配：(action, condition) 对：有点像OpenFlow 转发表(Ch. 4)！

action	source address	dest address	protocol	source port	dest port	flag bit
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	---
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	----
deny	all	all	all	all	all	all

Security: 8-158

有状态分组过滤

无状态分组过滤器：

- 防火墙会让“无意义”的分组合通过，例如：dest port = 80, ACK bit set
- 该TCP连接甚至都没建立起来：

action	source address	dest address	protocol	source port	dest port	flag bit
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK

有状态的分组过滤器：跟踪每个TCP连接的状态

- 跟踪TCP连接建立（SYN），拆除（FIN）：然后才让相应后续分组合通过
- 防火墙上的非活跃连接会超时，不再允许相应的分组合通过防火墙

Security: 8-159

有状态分组过滤

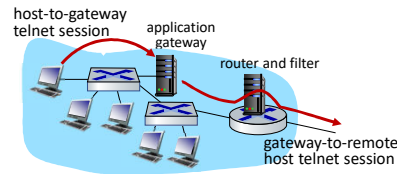
ACL增强：在允许分组合通过之前需要检查**连接状态表**

action	source address	dest address	proto	source port	dest port	flag bit	check connection
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any	
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK	X
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	---	
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	----	X
deny	all	all	all	all	all	all	

Security: 8-160

应用程序网关

- 根据应用数据的内容来过滤进出的数据报，就像防火墙根据IP/TCP/UDP字段来过滤一样
- 例子：**允许特定的内部站点登录到外部服务器，但不是直接登录



- 需要所有的telnet用户通过网关来telnet
- 对于认证的用户而言，网关建立和目标主机的telnet connection，网关在2个连接上进行中继
- 路由器过滤器将所有不是来自网关的telnet分组全部过滤掉

Security: 8-161

防火墙和应用程序网关的局限性

- IP spoofing:** 路由器不知道数据报是否真的来自于分组源地址声称的IP
- 应用网关：如果有多个应用需要控制，就需要有多个应用程序网关
- 而且客户端软件需要知道如何连接到这个应用网关
 - e.g., 必须在Web browser中配置网络代理的Ip地址
- 过滤器对UDP段所在的分组，或者全过或者全都不过
- 折中：**外部通信的便利性vs安全的级别
- 很多高度保护的站点仍然受到攻击的困扰

Security: 8-162

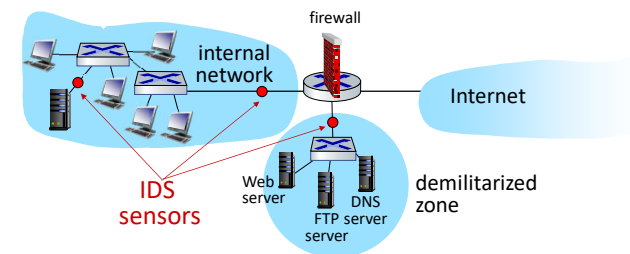
IDS: 入侵检测系统

- 分组过滤：**
 - 对TCP/IP头部字段进行检查
 - 不检查会话分组间的相关性
- IDS: intrusion detection system**
 - 深入分组检查：**检查分组的内容（e.g., 检查分组中的串是否和已知攻击数据库的病毒和攻击的特征码匹配）
 - 检查分组间的**相关性**，判断是否是有害的分组（时间序列）
 - 端口扫描
 - 网络映射
 - DoS 攻击

Security: 8-163

IDS: 入侵检测系统

- 多个IDSs: 不同的网段，放置探针，根据需要进行不同类型的检查



Security: 8-164

2025中科大高网

总 结

基本原理

- 加密（对称和公开密钥加密体系）
- 报文完整性
- 端到端认证（鉴别）

各个层次的安全性

- 安全电子邮件
- 安全传输(TLS)
- IPSec
- 802.11、4G/5G

网络安全设备：防火墙和IDS



Security: 8-165